

RQ	Theme	Code	Quotation
RQ2	Cyber Threats & Attack Paths	Data, signal or configuration manipulation	EXP-01 [Q8/Q10]: Yes. We have already had our cybersecurity arrangements audited by a classification-related third party, and we passed. There was also discussion about Modbus TCP/IP communication because release signals were coming from a third party into our system. The important point was what could actually be changed from outside. You cannot directly change how the pump unit operates or its firefighting capacity. You may be able to affect whether a section is opened or not, so you can do some harm, but not the kind of harm that compromises the complete system. That is how we do it. EXP-01 [Q10]: A lot relies on the equipment being installed in user-access-controlled areas, and that is something we cannot fully control. We can only give guidance. Once the system is delivered, we cannot control what somebody does with the electrical cabinet or where exactly it is installed. We do not monitor whether somebody physically opens the electrical cabinet, but we do monitor the network. If somebody unplugs a cable, for example, we get an alarm. So cable breaks or attempts to manipulate the network EXP-03 [Q3]: Yes. This is an interesting point because the normal industrial practice is that the safest way to protect the system is not to connect it to the internet at all. Realistically, though, with this framework you could potentially convince the customer to move toward a connected system if the benefits are clear. For example, the customer could get real-time monitoring, and maintenance-level access could support diagnostics and troubleshooting without giving direct operational control. That could reduce system downtime, so there is a realistic benefit that could help justify the connection. There is also a wider concern. If the customer allows external connections not only for the fire-suppression system but also for many other critical onboard systems, the ship could end up with many separate external connection points. Even if every connection is protected, having many gateways increases the overall exposure. If one of them is compromised, it could become a serious problem for the vessel. EXP-09 [Q9]: I cannot comment in detail on the technical threat analysis, but ship systems in general can be compromised. One practical concern is weak password protection. I have seen situations where a customer was able to gain access to a password-protected controller even though they were not intended to have that level of access. That suggests that controller credentials and access protection need to be treated very carefully. EXP-12 [Q6]: In principle, yes, but the controls need to be applied at the right level. For a connected monitoring or cloud service, stronger user management and cybersecurity controls are clearly needed. At the device level, however, implementing local user management on PLC-based equipment may add too much complexity and may not even be practical with the current device capabilities. There is also a trade-off. If local user management requires a connection to supplier servers or to the vessel IT environment, that new connection can itself introduce additional risk. It could also turn each project into a broader IT integration project. For simple equipment-level control of pumps, valves, and local controllers, it may therefore be better to keep the control system simpler and use other protective measures rather than force every whole-vessel IT requirement down to the device level. EXP-01 [Q10]: A lot relies on the equipment being installed in user-access-controlled areas, and that is something we cannot fully control. We can only give guidance. Once the system is delivered, we cannot control what somebody does with the electrical cabinet or where exactly it is installed. We do not monitor whether somebody physically opens the electrical cabinet, but we do monitor the network. If somebody unplugs a cable, for example, we get an alarm. So cable breaks or attempts to manipulate the network EXP-03 [Q4]: As a stand-alone supplier system, the framework is very good. But in the future, I think ships may combine the externally connected critical systems through one protected ship-level connection point or server. That server could collect the necessary information from systems such as fire suppression, machinery, and energy monitoring, and then external applications or suppliers would obtain selected data through that protected ship-level interface. In my view, that could be stronger than every individual vendor maintaining its own external connection, because the vessel or system integrator can protect and control one EXP-05 [Q4/Q9]: Someone could compromise a service computer and, when that computer is taken onsite for service, malware could be introduced into the system. EXP-08 [Q2]: Pretty much. At least the core system that generates alarms or performs actuation could be considered trusted. Everything outside the fire-suppression system supplier's own delivery could then be considered untrusted.
		DoS / communication disruption	
		Malware / third-party compromise	
		Physical intrusion & attack propagation	EXP-01 [Q4]: You should also talk about the physical locations of the equipment. Later, you talk about user profiles, roles, access, passwords, and things like that. But for fire suppression and the panels, they should always be available without first needing to log in. At the same time, they need to be located somewhere where people cannot just manipulate them. That is why we advise the integrator that they need to be located in user-access-controlled areas, such as the bridge or the ECR. That way, some of the password-management burden can be reduced. You should mention that the equipment, whether it is an electrical cabinet, HMI panel, pump unit, or something similar, should be in an access-controlled area so that not everybody can access it without EXP-01 [Q6]: Those are more on the software side, for example SCADA and PLC systems. The cybersecurity requirements talk about user profiles and passwords, but for the fire-suppression panel, it should always be available so that you can immediately release or operate the system. You should not need to log in first. That is one of the difficult points when applying the standards. At the moment, we do not really have full role-based access. We mainly have one service access level for doing updates or similar work, and we are even considering whether that could be avoided. Passwords also create additional requirements: password length, failed-login handling, logging of failed attempts, and so on. All of that adds requirements to the software. For normal operation, release is done physically onboard the vessel and does not require a password because the equipment is already in a user-access-controlled area. It is not sitting on an open deck where anybody can access it. So there is physical security as well.

RQ	Theme	Code	Quotation
			EXP-01 [Q10]: A lot relies on the equipment being installed in user-access-controlled areas, and that is something we cannot fully control. We can only give guidance. Once the system is delivered, we cannot control what somebody does with the electrical cabinet or where exactly it is installed. We do not monitor whether somebody physically opens the electrical cabinet, but we do monitor the network. If somebody unplugs a cable, for example, we get an alarm. So cable breaks or attempts to manipulate the network EXP-01 [Q13]: Maybe simplify the zones and layers a little bit.EXP-01 [Q14]: Try to highlight the physical user access as well. The architecture is currently more focused on the software side, but it is quite simple to add the requirement that access points to the system should be located in user-access-controlled areas. There is also the practical issue of physical ports. The standard says that unused open ports should be disabled. In practice, if a panel is installed inside a console or another user-access-controlled location, physically reaching and manipulating that connection may already require a significant amount of effort. So the physical-access EXP-07 [Q8]: Yes. I think these are realistic cases that could actually happen.EXP-07 [Q9]: I think the main priority should be the security of access from the untrusted zone. That is the biggest concern. On a passenger vessel, the equipment is normally installed in spaces that passengers cannot access. A crew member could potentially gain physical access and connect something directly to the network, but that becomes more of a physical-security issue and is probably less likely than an attack through an external or
		Unauthorized / remote access	EXP-01 [Q1]: Yeah. In my opinion, maybe a bit too much. There are too many layers and too many zones. Of course, it is quite a heavy topic because we talk about layers and we talk about zones. I think the layers are more like, in a software way, where you do the stuff, while the zones are more physical. Part of that also goes to the system integrator, which is the shipowner or shipbuilder. If you first think about the zones, I do not think we need a separate fire-suppression zone; we could just have the safety-function zone. The maintenance and engineering zone is also a bit much. I would almost lose it or place those functions between the supervisory and safety areas. The fire-suppression equipment itself should already be in a user-access-controlled place. It is not for everybody. You should not allow everybody to come there, supervise it, or use it. In the same way, the operational panels should also be in restricted areas. And communication between a third party and our system should be quite isolated from everything else. EXP-01 [Q5]: It also depends on how the software is implemented, because that is process-specific. But generally, if you have a connection toward an untrusted network, the best choice is to send only information and alarms there. There should not be direct control of anything. If control from outside is allowed, then it needs to go through a firewall, and you need to control who communicates with us and what kind of commands they can give. It also depends on which commands are allowed. Usually, you might allow a command to release a section valve, but you cannot directly command how the pumping works. It goes through our automation system before it reaches the pump units. So, yes, somebody might be able to manipulate a command and release a section valve. That is unfortunate, but it does not compromise the whole system. EXP-01 [Q6]: Those are more on the software side, for example SCADA and PLC systems. The cybersecurity requirements talk about user profiles and passwords, but for the fire-suppression panel, it should always be available so that you can immediately release or operate the system. You should not need to log in first. That is one of the difficult points when applying the standards. At the moment, we do not really have full role-based access. We mainly have one service access level for doing updates or similar work, and we are even considering whether that could be avoided. Passwords also create additional requirements: password length, failed-login handling, logging of failed attempts, and so on. All of that adds requirements to the software. For normal operation, release is done physically onboard the vessel and does not require a password because the equipment is already in a user-access-controlled area. It is not sitting on an open deck where anybody can access it. So there is physical security as well. EXP-01 [Q8/Q10]: Yes. We have already had our cybersecurity arrangements audited by a classification-related third party, and we passed. There was also discussion about Modbus TCP/IP communication because release signals were coming from a third party into our system. The important point was what could actually be changed from outside. You cannot directly change how the pump unit operates or its firefighting capacity. You may be able to affect whether a section is opened or not, so you can do some harm, but not the kind of harm that compromises the complete system. That is how we do it. EXP-01 [Q9]: One thing is the internal network itself. During the audit, they also monitored whether we had unused services or ports open on the internal network. That should be considered as well. EXP-01 [Q12]: That is going to be tricky. It depends on the customer. You would really need to explain why you need access through the maintenance path. On some projects, we have previously delivered a dedicated remote-access device inside the cabinet, so that kind of maintenance connection has been done before. The monitoring part is more difficult. Customers may not want to allow us to have an external monitoring connection, even if we provide our own connection point, because the shipowner or system integrator takes responsibility for the overall cybersecurity of the vessel. They want to monitor and control the point where external connections leave the vessel. If there are, for example, hundreds of onboard systems and every supplier has its own external communication link, it becomes a nightmare for the system integrator. If the customer wants this kind of monitoring, then it can be done, but it will depend on their architecture, how much it is used, how much data is sent, and whether the data flow is one-way or EXP-02 [Q3]: One thing I was thinking about was the security level. Could it be shown as going from low to high? That could simplify the diagram a lot for me. It would make it easier to understand if the untrusted-network zone is clearly the lower-security area and the fire-suppression zone is clearly the high-security area. I would perhaps also add who has access to each of these areas, for example which onboard personnel have access to each security level or zone.

RQ	Theme	Code	Quotation
			EXP-03 [Q3]: Yes. This is an interesting point because the normal industrial practice is that the safest way to protect the system is not to connect it to the internet at all. Realistically, though, with this framework you could potentially convince the customer to move toward a connected system if the benefits are clear. For example, the customer could get real-time monitoring, and maintenance-level access could support diagnostics and troubleshooting without giving direct operational control. That could reduce system downtime, so there is a realistic benefit that could help justify the connection. There is also a wider concern. If the customer allows external connections not only for the fire-suppression system but also for many other critical onboard systems, the ship could end up with many separate external connection points. Even if every connection is protected, having many gateways increases the overall exposure. If one of them is compromised, it could become a serious problem for the vessel. EXP-05 [Q2]: I think it is quite simplified.EXP-05 [Q4]: Yes. Temporary access should also be considered when service personnel go to the customer site. EXP-07 [Q3]: Yes, I think it is mostly realistic. One difficulty is that the Safety Function Zone and the physical fire-suppression functions cannot always be fully separated in a real implementation. In this particular case, if you gain access to some safety-control functions, that may also provide access toward the fire-suppression functions. So that boundary can be difficult to realise exactly as shown, but otherwise the separation is realistic. EXP-07 [Q8]: Yes. I think these are realistic cases that could actually happen.EXP-07 [Q9]: I think the main priority should be the security of access from the untrusted zone. That is the biggest concern. On a passenger vessel, the equipment is normally installed in spaces that passengers cannot access. A crew member could potentially gain physical access and connect something directly to the network, but that becomes more of a physical-security issue and is probably less likely than an attack through an external or EXP-08 [Q2]: Pretty much. At least the core system that generates alarms or performs actuation could be considered trusted. Everything outside the fire-suppression system supplier's own delivery could then be considered untrusted. EXP-08 [Q8]: Yes, they look realistic. The assessment may not be complete, because it may not be possible to imagine every type of threat in advance. EXP-09 [Q7]: The main concern is the possibility of a security breach when access is provided. Normally we do not want to give customers broad access to the system. If access is limited mainly to monitoring, the users are clearly responsible, and passwords and permissions are properly managed, then it should be manageable. It would still create some additional responsibility for the after-sales organisation, and it would probably not be suitable for every vessel or every customer. EXP-09 [Q9]: I cannot comment in detail on the technical threat analysis, but ship systems in general can be compromised. One practical concern is weak password protection. I have seen situations where a customer was able to gain access to a password-protected controller even though they were not intended to have that level of access. That suggests that controller credentials and access protection need to be treated very carefully. EXP-12 [Q6]: In principle, yes, but the controls need to be applied at the right level. For a connected monitoring or cloud service, stronger user management and cybersecurity controls are clearly needed. At the device level, however, implementing local user management on PLC-based equipment may add too much complexity and may not even be practical with the current device capabilities. There is also a trade-off. If local user management requires a connection to supplier servers or to the vessel IT environment, that new connection can itself introduce additional risk. It could also turn each project into a broader IT integration project. For simple equipment-level control of pumps, valves, and local controllers, it may therefore be better to keep the control system simpler and use other protective measures rather than force every whole-vessel IT requirement down to the device level. EXP-01 [Q5]: Yes. There should always be a backup if the automation fails.EXP-01 [Q5]: I think it is quite robust. The main risk is the untrusted-network connection, but otherwise, no. EXP-01 [Q6/Q7]: Those are possible. Some of them already come from the components and controller platform itself, such as traffic filtering. On the recovery side, we also have redundancy, and we provide software backups so the software can be restored if EXP-05 [Q5]: It will work by itself. We can also use the manual releases.EXP-05 [Q6]: The data connection should support real-time data, with information stored locally and available for extraction when needed. EXP-07 [Q5]: Yes. That is also the current default approach.EXP-07 [Q5]: No, I cannot see an obvious single point of failure in the framework. EXP-11 [Q6]: Yes. Most of these measures are realistic, and several are already present in some form. We already use password protection for certain functions, controlled VPN-based access for remote connections, network separation, restricted communication, internal monitoring and logging, version and change management, and protection of controller configurations. Recovery is currently supported through local backups, such as backup storage media. Controlled remote connectivity is also realistic. Some of the exact authentication mechanisms may still need further development, but overall the measures are achievable. EXP-12 [Q9]: No. I think you have covered the main scenarios well.EXP-12 [Q9]: Micro-segmentation should receive more attention. Denial-of-service is also something that should be considered. Recovery and restoration are especially important, and not only for cybersecurity. The same capability is needed for hardware or equipment failures so that people onboard can restore the system and replace failed equipment.
RQ3	Recovery	Recovery & restoration	

RQ	Theme	Code	Quotation
	Resilience & Containment	Fault & alarm visibility	EXP-01 [Q10]: A lot relies on the equipment being installed in user-access-controlled areas, and that is something we cannot fully control. We can only give guidance. Once the system is delivered, we cannot control what somebody does with the electrical cabinet or where exactly it is installed. We do not monitor whether somebody physically opens the electrical cabinet, but we do monitor the network. If somebody unplugs a cable, for example, we get an alarm. So cable breaks or attempts to manipulate the network EXP-01 [Q11]: I think it is quite a good pipeline. We have already done many of these things, so not all of it is new to us, but it brings together many things that need to be considered. Especially the cybersecurity part is a good summary of what is listed in the standards, such as audit logging and monitoring. If you have user roles or device access, and people log in or log out, those events should be recorded in the logs. Password requirements and related security events also need to be handled. EXP-08 [Q14]: From my experience, the core system that makes the fire-suppression system functional without any outside connections should be clearly separated from all outside connections. Cybersecurity measures should first be designed properly around that core system, and only then should outside connections be added while keeping those principles intact. In practice, an important preventive measure is to keep the core equipment inside access-controlled spaces. The system should also detect any physical tampering. If someone gains access to a control cabinet, unplugs something, or connects a new device, that should be detected immediately and should generate an alarm so that someone can intervene. For the core equipment itself, user logins may not always be the most important protection. If physical access to the equipment is already tightly controlled and any interaction or tampering is immediately detected, that can be more important than adding further hardening that could complicate essential EXP-12 [Q5]: The micro-segmentation needs to be defined more clearly in the architecture. Another important point is alarm and degraded-state awareness. If a cyber incident or component loss occurs but the crew does not receive an alarm, the system has effectively failed in another way because people do not know that manual action may be required. Redundant controllers therefore need to be configured so that failures are detected and an alarm clearly indicates that the system is no longer fully functional. EXP-12 [Q12]: First, I would define the micro-segmentation more clearly. Second, I would link the architecture directly to the applicable requirements. If we have an IT or control-system topology and a cybersecurity design, I want to be able to point from each relevant IEC 62443 requirement to the architectural feature that addresses it. The same traceability is important for IACS UR E27 and classification-society approval. If the architecture is taken into use, the next step is to build the approval documentation from those
		Independent / degraded / manual operation	EXP-01 [Q1]: Yeah. In my opinion, maybe a bit too much. There are too many layers and too many zones. Of course, it is quite a heavy topic because we talk about layers and we talk about zones. I think the layers are more like, in a software way, where you do the stuff, while the zones are more physical. Part of that also goes to the system integrator, which is the shipowner or shipbuilder. If you first think about the zones, I do not think we need a separate fire-suppression zone; we could just have the safety-function zone. The maintenance and engineering zone is also a bit much. I would almost lose it or place those functions between the supervisory and safety areas. The fire-suppression equipment itself should already be in a user-access-controlled place. It is not for everybody. You should not allow everybody to come there, supervise it, or use it. In the same way, the operational panels should also be in restricted areas. And communication between a third party and our system should be quite isolated from everything else. EXP-01 [Q5]: Exactly. It is a false activation. The pump is still available, and if there is a real alarm somewhere else, the system can still operate. Even if our automation system goes down, the local panels can still be used to manually open the section valve, and the pump unit can still be operated manually. The fire-suppression capability is therefore not compromised. EXP-01 [Q5]: It also depends on how the software is implemented, because that is process-specific. But generally, if you have a connection toward an untrusted network, the best choice is to send only information and alarms there. There should not be direct control of anything. If control from outside is allowed, then it needs to go through a firewall, and you need to control who communicates with us and what kind of commands they can give. It also depends on which commands are allowed. Usually, you might allow a command to release a section valve, but you cannot directly command how the pumping works. It goes through our automation system before it reaches the pump units. So, yes, somebody might be able to manipulate a command and release a section valve. That is unfortunate, but it does not compromise the whole system. EXP-01 [Q5]: Yes. There should always be a backup if the automation fails.EXP-01 [Q5]: I think it is quite robust. The main risk is the untrusted-network connection, but otherwise, no. EXP-01 [Q6]: Those are more on the software side, for example SCADA and PLC systems. The cybersecurity requirements talk about user profiles and passwords, but for the fire-suppression panel, it should always be available so that you can immediately release or operate the system. You should not need to log in first. That is one of the difficult points when applying the standards. At the moment, we do not really have full role-based access. We mainly have one service access level for doing updates or similar work, and we are even considering whether that could be avoided. Passwords also create additional requirements: password length, failed-login handling, logging of failed attempts, and so on. All of that adds requirements to the software. For normal operation, release is done physically onboard the vessel and does not require a password because the equipment is already in a user-access-controlled area. It is not sitting on an open deck where anybody can access it. So there is physical security as well. EXP-03 [Q5]: Yes. If you move all the way down through the zones and even the final safety-control level is compromised, that is already a very severe situation. Even then, the system can still operate in manual mode. There may be no automatic release, but the vessel would still retain manual fire-suppression capability. A person can detect the fire, use the manual release, and operate the